



GeT a CAKE: Generic Transformations from Key Encapsulation Mechanisms to Password Authenticated Key Exchanges

Hugo Beguinet^{1,2(✉)}, Céline Chevalier^{1,3}, David Pointcheval¹,
Thomas Ricosset², and Mélissa Rossi⁴

¹ DIENS, École Normale Supérieure, CNRS, Inria, PSL University, Paris, France
`celine.chevalier@ens.fr`, `david.pointcheval@ens.fr`

² Thales, Gennevilliers, France
`hugo.beguinet@ens.fr`, `hugo.beguinet@thalesgroup.com`,
`thomas.ricosset@thalesgroup.com`

³ CRED, Université Paris-Panthéon-Assas, Paris, France

⁴ ANSSI, Paris, France
`melissa.rossi@ssi.gouv.fr`

Abstract. Password Authenticated Key Exchange (PAKE) have become a key building block in many security products as they provide interesting efficiency/security trade-offs. Indeed, a PAKE allows to dispense with the heavy public key infrastructures and its efficiency and portability make it well suited for applications such as Internet of Things or e-passports. With the emerging quantum threat and the effervescent development of post-quantum public key algorithms in the last five years, one would wonder how to modify existing password authenticated key exchange protocols that currently rely on Diffie-Hellman problems in order to include newly introduced and soon-to-be-standardized post-quantum key encapsulation mechanisms (KEM). A generic solution is desirable for maintaining modularity and adaptability with the many post-quantum KEM that have been introduced.

In this paper, we propose two new generic and natural constructions proven in the Universal Composability (UC) model to transform, in a black-box manner, a KEM into a PAKE with very limited performance overhead: one or two extra symmetric encryptions. Behind the simplicity of the designs, establishing security proofs in the UC model is actually non-trivial and requires some additional properties on the underlying KEM like fuzziness and anonymity. Luckily, post-quantum KEM protocols often enjoy these two extra properties. As a demonstration, we prove that it is possible to apply our transformations to Crystals-Kyber, a lattice-based post-quantum KEM that will soon be standardized by the National Institute of Standards and Technology (NIST).

Supplementary Information The online version contains supplementary material available at https://doi.org/10.1007/978-3-031-33491-7_19.

In a nutshell, this work opens up the possibility to securely include post-quantum cryptography in PAKE-based real-world protocols.

Keywords: Key Encapsulation Mechanism · Password-Authenticated Key Exchange · Universal Composability

1 Introduction

A Password Authenticated Key Exchange (PAKE) protocol allows two users to derive a secret key over insecure channels only with the premise of sharing the same low entropy password. PAKE has become increasingly relevant in recent years due to the proliferation of connected devices and the growing demand for secure communication in scenarios where a public key infrastructure (PKI) may not be practical or desirable. It is particularly appealing for use cases like the Internet of Things (IoT) or e-passports, where portability, independence, and efficiency are important considerations. For IoT devices, for example, PKI is not feasible because of the number of devices and their limited computing resources and connectivity. PAKE allows these devices to securely communicate with each other using a simple password that can be easily changed if compromised. Similarly, in the case of e-passport, PAKE can be used to establish secure communication between the passport and a reader without the need for a PKI. It allows for a more portable and independent solution, as no central authority is necessary to verify a passport's authenticity. Overall, PAKE offers a trade-off between security and efficiency as compared to traditional authenticated key exchange protocols in certain circumstances.

Security models for PAKEs The security of PAKE will always be weaker than the security of PKI-based authenticated key exchange. Indeed, the presence of a low-entropy password allows powerful dictionary attacks. The conceptual idea in the PAKE security models is to accept the possibility of such dictionary attacks *but to prove that they must be made online*, i.e. that no password validity test is accessible offline. This slight security regression compared to authenticated key exchange is often accepted because online dictionary attacks are rarely relevant in practical contexts and the efficiency gain of PAKE is much higher. Moreover one can always block a user after a certain number of failed attempts. More formally, for proving the security of PAKE, the dictionary attacks should then be materialized in the existing security models for authenticated key exchange. Several solutions have emerged and have been refined over the last decade. Today, there are two main security models for PAKE protocols: the Bellare-Pointcheval-Rogaway [BPR00] and the Universal Composability (UC) model [Can01, CR03] with its PAKE's version [CHK+05]. The BPR model, introduced by Bellare, Pointcheval, and Rogaway, is a game-based security model that uses specific games to evaluate the ability of an adversary to break the protocol. On the other hand, the UC model, introduced by Canetti, is a simulation-based model that provides strictly better security guarantees, as stated in the original UC PAKE paper [CHK+05].

Existing work on PAKE. The concept of PAKE was formalized and analyzed during the 1990s by Bellare and Meritt with the Encrypted Key Exchange (EKE) protocol [BM92]. Since then, various PAKE protocols have been proposed, with some standardized by organizations such as the Internet Engineering Task Force (IETF) [Sch17]. Over the years, two main categories of PAKE appeared. The first use passwords to obscure the exchanged messages while the second use them as part of the randomness to build the necessary material, like the group generator. EKE [BM92] and OEKE [BCP03] are typical examples of the former. And SPEKE [Mac01] or CPace [AHH22] are examples for the latter. While many different PAKE designs have been introduced, not all are proven in the strong UC security model. In the previous examples of PAKE constructions, EKE [DHP+18], OEKE [ACCP08] and CPace [AHH21] have been proven in the UC model.

Post-quantum threat. While vastly used in current security products like IoT or e-passports, all these PAKE constructions rely on the Diffie-Hellman key exchange to provide cryptographic security. It raises concerns about their long-term security, as the emergence of quantum computing in recent years threatens any Diffie-Hellman-based key exchange, and thus any currently used PAKE. Indeed, quantum computers would potentially break, even retroactively, the mathematical foundations of many current cryptographic systems including the difficulty of the Diffie-Hellman problem. Therefore, it is crucial to carefully consider the long-term security of PAKE protocols and design them accordingly. In response to this potential threat to current cryptographic systems, the National Institute of Standards and Technology (NIST) has launched a standardization process for post-quantum cryptographic primitives in 2017. The goal of this campaign is to provide new post-quantum standards for two basic and crucial cryptographic building blocks: Key Encapsulation Mechanisms (KEMs) and digital signatures. These two families of public-key algorithms may be used on their own but more importantly, the future standards are destined to be included as black-boxes in internet and IoT protocols to complement the pre-quantum bricks. Many different families of mathematical problems were used for the design of candidate algorithms like error correcting codes or lattices. The analysis of the different candidate algorithms is currently ongoing but the NIST has announced a first set of standards in 2022 including the lattice-based KEM Crystals-Kyber [SAB+22]. More recently, specific PAKE constructions using post-quantum cryptography, in particular, lattices assumptions, were introduced. However most lattice constructions are either proven in weaker security models [GDLL17] or using mechanisms that are highly inefficient in practice [BCV19, ZY17].

1.1 Our Contributions

This paper proposes the first generic constructions to transform a black-box KEM into a PAKE. The idea is natural and inspired from EKE and OEKE. In high level, it consists in encrypting the public key using the password as a secret key. A second modification consists in either encrypting the ciphertext with that

same password or adding an authentication tag. The first transformation is called CAKE, derived from K(EM-to-P)AKE, and the second transformation is called OCAKE. Both constructions are graphically sketched later in the paper in Figs. 4 and 5. By design, they are simple, efficient and easy to implement. However, the price for such simplicity must be paid on the analysis side.

Let us first intuitively discuss the requirements on the KEM for achieving formal security. Consider a KEM where the public key is designed with a particular shape, for example, the public key might always be composed of small coefficients. When encrypted, the distribution of the sent message would look uniformly distributed. However, any attacker may perform an offline dictionary attack: given an encrypted public key, it will be possible to leverage the particular public key form as a condition for the valid password. In such case, the correct password will be the one that decrypts to a public key with small coefficients. Hence, an indistinguishability property on the distribution of the public key, called *fuzziness* (formally defined in Definition 3), will be required to avoid offline dictionary attacks. Likewise, such property on the ciphertext, called *anonymity* (formally defined in Definition 4), will be essential. In addition, another important property should be fulfilled by the symmetric encryption to construct such PAKE. The needed property is ensured by the Ideal Cipher (IC) model [BPR00]. It consists in assuming that the encryption behaves like a random permutation on every key. While it does not retain clear weaknesses to use a relaxed model, an ideal cipher is necessary to unwrap the proofs of our theorems.

In this paper, we successfully prove our CAKE and OCAKE constructions in the UC model assuming the above properties, the random oracle model (ROM) and the erasure model stating that any obsolete internal information is erased.

Why two constructions? Similarly to EKE and OEKE, CAKE and OCAKE offer slightly different security/efficiency trade-offs. Let us compare both constructions:

- The first construction, CAKE, consists in encrypting both exchanged messages. It leads to an implicitly authenticated key exchange protocol based on passwords. However a participant is not sure that the opposing party is able to obtain the session key. This assurance can only be achieved by explicit authentication. The security model for proving CAKE is very strong as it captures adaptive corruptions. In other words, the model allows an attacker to corrupt a user and thus obtain all its internal state in an adaptive way during an ongoing execution of the protocol.
- In order to add explicit authentication of the receiver, one usually includes a key-confirmation tag. In this case, one can remark with OCAKE that only one symmetric encryption is required. The second encryption is just replaced by the authentication that provides an explicit authentication to the receiver. However, this construction can only be proven secure in the static corruption model where the attacker may still corrupt users but the choice should be made before the execution of the protocol. Additionally, it is here possible to add an explicit client authentication at the end of the exchange to provide mutual explicit authentication.

In complement, we propose to show that the assumed properties on the KEM are not just artifacts that allow our proof to work. They are actually verified in concrete KEMs. We choose the example of Crystals-Kyber [SAB+22] as our guinea pig for applying our transformations. Crystals-Kyber is a future NIST post-quantum standard. We formally demonstrate that Kyber validates fuzziness and anonymity leading up to security statements for CAKE-Kyber (Theorem 3) and OCAKE-Kyber (Theorem 4).

1.2 Outline of the Paper

In Sect. 2, we introduce the preliminary notions on KEM, their security properties with some lattice definitions and a brief introduction to Kyber. In Sect. 3, we provide all the necessary information about PAKEs and their security in the UC model. In Sect. 4, we present both our KEM to PAKE transformations along with their security statements. For space reasons, the proofs are sketched in the main body of the paper and the full simulations are detailed in Appendices A and B (however full proofs are detailed in the same appendices of the full version that can be found here: [BCP+23]). Finally, we demonstrate our techniques on Kyber in Sect. 5.

2 Preliminaries

2.1 Notations

We note scalars, vectors, and matrices with lowercase plain (i.e. n), lowercase bold (i.e. $\mathbf{e}$), and uppercase bold (i.e. $\mathbf{A}$), respectively. We denote by $\text{negl}(\kappa)$ a negligible function of a security parameter κ . Given a finite set S , the notation $x \leftarrow S$ means a uniformly random assignment of an element of S to the variable x . We note KEM the denomination of a key exchange mechanism and refer to KEM for the specific key encapsulation mechanism algorithm.

2.2 Key Encapsulation Mechanism

Even if the Key Encapsulation Mechanism’s denomination is relatively recent, KEMs have been widely used throughout the history of public key cryptography. The first illustration is the fact that ElGamal [ElG85], based on the Diffie-Hellman key exchange, can be easily seen as a KEM. We will demonstrate later in this section that it enjoys several security notions, such as *semantic security*, *fuzziness*, and *anonymity*. Thereafter, with the NIST competition, many new researches have conducted to the introduction of KEM using a wide variety of structures. Let us cite a few examples: SABER [DKRV18,DKR+20], Crystals-Kyber [BDK+18,SAB+22], NewHope [ADPS16,PAA+19] on lattice-based assumptions or alternatively McEliece [McE78,ABC+22] on code-based assumptions.

Definition 1 (Key Encapsulation Mechanism). A *Key Encapsulation Mechanism* (KEM) is a triple of algorithms (*KeyGen*, *Encaps*, *Decaps*):

- *KeyGen*: Returns a pair of public-secret keys $(pk, sk) \in \mathcal{P} \times \mathcal{SK}$
- *Encaps*: Takes a public key $pk \in \mathcal{P}$ as input to produce a ciphertext $c \in \mathcal{C}$ and a key $K \in \mathcal{K}$. The ciphertext c is called an encapsulation of the key K ;
- *Decaps*: Takes a secret key $sk \in \mathcal{SK}$ and an encapsulation $c \in \mathcal{C}$ as input, and outputs $K \in \mathcal{K}$.

where $\mathcal{SK}$, $\mathcal{P}$, $\mathcal{C}$, and $\mathcal{K}$ are the sets of secret keys, public keys, ciphertexts and session keys.

The formalization of the sets $\mathcal{P}$, $\mathcal{C}$, and $\mathcal{K}$ will impact the security notions presented in the sequel.

Correctness. The correctness of a KEM requires that, for a security parameter κ ,

$$\Pr \left[\begin{array}{l} (pk, sk) \leftarrow \text{\$} \text{KeyGen}(1^\kappa) \\ (c, K) \leftarrow \text{Encaps}(pk) \end{array} : \text{Decaps}(sk, c) = K \right] > 1 - \text{negl}(\kappa).$$

Security Notions. The usual security notion for KEM is *semantic security*, also known as *indistinguishability*:

Definition 2 (Indistinguishability). We define the advantage of any adversary $\mathcal{A}$ in deciding the key of the KEM by:

$$\text{Adv}_{\text{KEM}}^{\text{ind}}(\mathcal{A}) = \left| \Pr_{D_R}[\mathcal{A}(c, K) = 1] - \Pr_{D_S}[\mathcal{A}(c, K') = 1] \right|.$$

where we consider the real and random distributions

$$\begin{aligned} D_R &= \{(pk, sk) \leftarrow \text{KeyGen}(1^\kappa); (c, K) \leftarrow \text{Encaps}(pk) : (c, K)\}, \\ D_S &= \{(pk, sk) \leftarrow \text{KeyGen}(1^\kappa); (c, K) \leftarrow \text{Encaps}(pk); K' \leftarrow \text{\$} \mathcal{K} : (c, K')\}. \end{aligned}$$

In all the advantage definitions, we will denote $\text{Adv}_{\text{KEM}}^{\text{ind}}(t)$ the maximal advantage any adversary can have within time t .

Let us introduce additional properties for KEMs, on the distributions of the public keys and of the encapsulations. We will denote by *fuzziness* the randomness of public keys, and by *anonymity* the randomness of the encapsulation. The latter is the usual definition, when the ciphertext distribution does not depend on the public key, and thus does not leak any information about the recipient.

Definition 3 (Fuzzy KEM). A KEM is said *fuzzy* if the distribution of the public keys output by the *KeyGen* algorithm are computationally indistinguishable from uniform keys in $\mathcal{P}$. More formally, we define the advantage of any adversary $\mathcal{A}$ in breaking the fuzziness of the KEM by:

$$\text{Adv}_{\text{KEM}}^{\text{fuzzy}}(\mathcal{A}) = \left| \Pr_{D_R}[\mathcal{A}(pk) = 1] - \Pr_{D_S}[\mathcal{A}(pk) = 1] \right|,$$

where

$$D_R = \{(pk, sk) \leftarrow \text{KeyGen}(1^\kappa) : pk\} \quad \text{and} \quad D_\$ = \{pk \leftarrow \$ \mathcal{P} : pk\}.$$

Definition 4 (Anonymous KEM). A KEM is said *anonymous* if the distribution of the ciphertexts outputted by the *Encaps* algorithm are computationally indistinguishable from uniform ciphertexts in $\mathcal{C}$. More formally, we define the advantage of any adversary $\mathcal{A}$ in breaking the anonymity of the KEM by:

$$\text{Adv}_{\text{KEM}}^{\text{ano}}(\mathcal{A}) = \left| \Pr_{D_R}[\mathcal{A}(c) = 1] - \Pr_{D_\$}[\mathcal{A}(c) = 1] \right|,$$

where

$$D_R = \{(pk, sk) \leftarrow \text{KeyGen}(1^\kappa); (c, K) \leftarrow \text{Encaps}(pk) : c\} \text{ and } D_\$ = \{c \leftarrow \$ \mathcal{C} : c\}.$$

ElGamal Key Encapsulation Mechanism. In order to illustrate the above notions, let us consider the particular KEM derived from the so-called ElGamal encryption scheme [ElG85]. Let $\mathbb{G}$ be a group of prime order q , spanned by an element g :

- *KeyGen*(1^κ): chooses a random $x \leftarrow \$ \mathbb{Z}_q$ and sets $sk \leftarrow x$, $pk \leftarrow g^x$, with $SK = \mathbb{Z}_q$ and $\mathcal{P} = \mathbb{G}$;
- *Encaps*(pk): chooses a random $r \leftarrow \$ \mathbb{Z}_q$ and sets $c \leftarrow g^r$, $K \leftarrow pk^r$, with $\mathcal{C} = \mathbb{G}$ and $\mathcal{K} = \mathbb{G}$;
- *Decaps*(sk, c): outputs $K \leftarrow c^{sk}$.

It is well-known that the indistinguishability of this KEM relies on the Decisional Diffie-Hellman assumption. From the above description, this is clear that public keys are uniformly distributed in $\mathbb{G}$, hence this KEM is fuzzy; and the ciphertexts are also uniformly distributed in $\mathbb{G}$, thus this KEM is also anonymous. Note that the ElGamal KEM actually validates even stronger properties: perfect fuzziness (or smoothness) and perfect anonymity. The perfect nature comes from the fact that these notions are no longer computational but statistically ensured. As will be later stated in Remark 1, these properties are less common for post-quantum KEM protocols and thus will not be considered as requirements for our constructions.

2.3 Learning with Errors

Three rounds of the NIST standardization campaign are already over and one type of hardness assumption seems to be more enticing: lattices. Lattice problems provide strong worst-case to average-case reductions, making them excellent candidates for long-term security. Indeed state of the art algorithm using quantum adversaries are not far more efficient compared to current existing algorithm to solve LWE. In this section, we introduce the Learning With Errors (LWE) [Reg06] assumptions. It can be divided into two problems: a decisional

and a search problems. Both are assumed intractable in reasonable time, even for a quantum computer. Let us introduce the decisional version.

We directly consider this problem in a module structure named Module-LWE (we refer to [LS15] for more details). We define $\mathcal{R}_q$ as the ring $\mathbb{Z}_q[X]/(X^n + 1)$. Let β_η be the distribution on $\mathcal{R}_q$ where each coefficient of the polynomial is generated according to a centered binomial distribution with parameter 2η . We define the oracle $\mathcal{O}_{m,k,\eta}^{\text{mlwe}}$ that outputs samples of the form $(\mathbf{A}, \mathbf{b} = \mathbf{A} \cdot \mathbf{s} + \mathbf{e})$ with $\mathbf{s} \leftarrow \beta_\eta^k$, $\mathbf{A} \leftarrow \mathcal{R}_q^{m \times k}$, and $\mathbf{e} \leftarrow \beta_\eta^m$.

Definition 5 (Decisional MLWE $_{m,k,\eta}$ Problem). *Given a set of parameters $m, k, \eta \in \mathbb{N}$, the advantage of any probabilistic polynomial time algorithm $\mathcal{A}$ in deciding the d-MLWE over $\mathcal{R}_q$ is:*

$$\text{Adv}_{m,k,\eta}^{\text{d-mlwe}}(\mathcal{A}) = \left| \frac{\Pr[(\mathbf{A}, \mathbf{b}) \leftarrow \mathcal{O}_{m,k,\eta}^{\text{mlwe}} : \mathcal{A}(\mathbf{A}, \mathbf{b}) = 1]}{-\Pr[(\mathbf{A}, \mathbf{b}) \leftarrow \mathcal{R}_q^{m \times k} \times \mathcal{R}_q^m : \mathcal{A}(\mathbf{A}, \mathbf{b}) = 1]} \right|.$$

2.4 CRYSTALS-Kyber

Crystals-Kyber, also known as **Kyber**, is a Module-LWE-based KEM that is one of the most efficient post-quantum solutions. It was introduced in response to the NIST call for standardization of post-quantum primitives and was accepted as the first post-quantum standard for key exchange in 2022. In its original paper [BDK+18], **Kyber** is proposed as a KEM that is secure against chosen-plaintext attacks (CPA-secure) and then achieves chosen-ciphertext attacks (CCA-secure) with the Fujisaki-Okamoto transform.

In Fig. 1, we present the CPA-secure version of **Kyber**, where $\mathcal{R}_q$ is the ring $\mathbb{Z}_q[X]/(X^n + 1)$. Following the last supplemented version (3.0) [SAB+22], the suggested parameters are defined as follows: $(X^n + 1)$ is the $2n$ -th cyclotomic polynomial where n and q are equal respectively to 256 and $q = 3329$.

Additionally, for the sake of efficiency, **Kyber** includes an optimization using a compression function that can be thought of as a bit cut. While we do not use this compression in our protocol for the sake of clarity, it should be included in any implementation of our protocols using **Kyber** for maximum efficiency and correctness. We refer to the most recent NIST submission package [SAB+22] for more detailed information.

3 Password Authenticated Key Exchange

3.1 Introduction to PAKE

Initially introduced by Bellare and Merritt [BM92], a Password-Authenticated Key Exchange (PAKE) is a protocol that allows two parties to establish a shared secret session key over an insecure communication channel using a password as the only authentication means. The goal of PAKEs is to ensure that the key exchange is secure even if the password is weak or stolen by an attacker, the

Kyber.KeyGen(1^κ)	Kyber.Encaps($pk = (\rho, \mathbf{b})$)
1 : $\rho, \sigma \leftarrow \mathcal{S}\{0, 1\}^\kappa$	1 : $\tau \leftarrow \mathcal{S}\{0, 1\}^\kappa$
2 : $\mathbf{A} \leftarrow \mathcal{R}_q^{k \times k} := \text{Sam}(\rho)$	2 : $m \leftarrow \mathcal{S}\{0, 1\}^n \subseteq \mathcal{R}_q$
3 : $(\mathbf{s}, \mathbf{e}) \leftarrow \beta_\eta^k \times \beta_\eta^k := \text{Sam}(\sigma)$	3 : $\mathbf{A} \leftarrow \mathcal{R}_q^{k \times k} := \text{Sam}(\rho)$
4 : $\mathbf{b} \leftarrow \mathbf{A} \cdot \mathbf{s} + \mathbf{e}$	4 : $(\mathbf{r}, \mathbf{e}', \mathbf{e}'') \leftarrow \beta_\eta^k \times \beta_\eta^k \times \beta_\eta := \text{Sam}(\tau)$
5 : return ($pk = (\rho, \mathbf{b}), sk = \mathbf{s}$)	5 : $\mathbf{u} \leftarrow \mathbf{A}^T \cdot \mathbf{r} + \mathbf{e}'$
	6 : $v \leftarrow \mathbf{b}^T \cdot \mathbf{r} + \mathbf{e}'' + \left\lceil \frac{q}{2} \right\rceil \cdot m$
	7 : return $c \leftarrow (\mathbf{u}, v)$
Kyber.Decaps($sk = \mathbf{s}, c = (\mathbf{u}, v)$)	
1 : return $\left\lceil \frac{2}{q} \left(v - \mathbf{s}^T \cdot \mathbf{u} \right) \right\rceil$	

Fig. 1. Simplified Kyber KEM: Kyber.KeyGen, Kyber.Encaps, Kyber.Decaps

only possible attack being an online exhaustive search, which can be detected and stopped using some organizational action.

PAKE protocols are handy when strong authentication is required while other forms of authentication (certificates) are not usable. They are often used in combination with other protocols to provide a secure channel for communication.

PAKE protocols might be vulnerable to two types of attacks: offline-dictionary attacks and online-dictionary attacks. The former occurs when an attacker gains knowledge of the password using pre computed lists of common passwords and exchanged information. Whereas, the latter involves an attacker actively trying to obtain the password by attempting to log in with different guesses. PAKE protocols often implement measures such as limiting the number of tries an attacker can make to guess the password to protect against online-dictionary attacks. Consequently, the security of a PAKE protocol ultimately relies on its resistance to offline-dictionary attacks. In other words, the strength of a PAKE protocol is determined by how difficult it is for an attacker to guess the password from the public transcript, even if it has a lot of time and resources.

3.2 The Universal Composability (UC) Model

Overview of the UC Framework. The Universal Composability (UC) model [Can01] is a simulation-based model in which an environment $\mathcal{Z}$ attempts to differentiate the output of a protocol execution Π in the real world from the output generated in an ideal world. In the real world, the execution takes place between parties and an potential adversary. In the ideal world, dummy players and an ideal adversary or simulator $\mathcal{S}$ interact solely with an ideal functionality $\mathcal{F}$ to compute a specific function f . The ideal functionality can be informally defined as a trusted party that honestly and unconditionally responds to any

query. A schematic representation is given in Fig. 2.

The original paper [Can01] only uses sid as session identifiers, but a improved version of the UC model was published in [CR03] introducing subsession identifiers ssid . For more clarity, throughout this article we use ssid for $(\text{sid}, \text{ssid})$. More explicitly, two ssid could theoretically be equal on different sessions sid , but by setting $\text{ssid} := (\text{sid}, \text{ssid})$, we enforce the uniqueness of ssid . This uniqueness is necessary in the proofs provided in Appendices A and B.

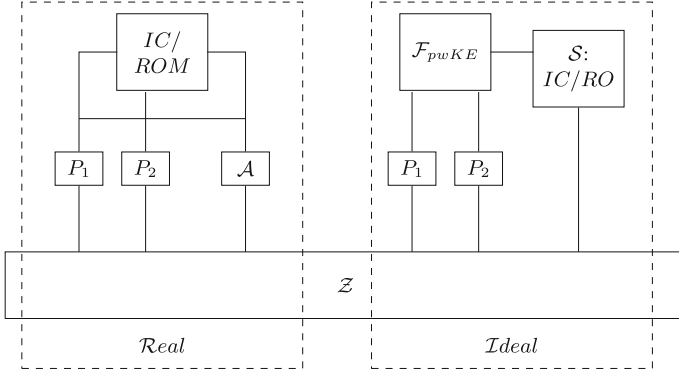


Fig. 2. *Real* versus *Ideal* world: $\mathcal{Z}$ capability.

The goal of the UC model is to emulate the protocol Π using the ideal functionality. If the emulation is performed such that the environment $\mathcal{Z}$ cannot distinguish (1) Π 's outputs with possible interactions with an adversary $\mathcal{A}$ from (2) the outputs of dummy parties and a simulator interacting with the ideal functionality $\mathcal{F}$, then one can state that Π UC-emulates $\mathcal{F}$.

In our case, the protocols are Password-Based Authenticated Key Exchange (PAKE) and the ideal functionalities used throughout the paper specifically designed for PAKEs [CHK+05, ACCP08] are $\mathcal{F}_{pwKE}$ and $\mathcal{F}_{pwKE-sA}$ (taken from [CHK+05] and defined in Fig. 3).

Ideal Functionality $\mathcal{F}_{pwKE}$. We present here the ideal functionality that is used for PAKEs. A detailed description of the functionality is given in [CHK+05]. It consists of three types of queries: **NewSession**, **TestPwd** and **NewKey**:

- **NewSession** allows a party to initialize a connection to another opposing party using its password. The functionality $\mathcal{F}_{pwKE}$ uses this query to record the connection as well as the initial party's password.
- **TestPwd** models the unique online password test (online dictionary attacks) that is enabled through the execution of a PAKE. This query additionally impacts the view of the ideal functionality. Querying **TestPwd** changes the view of $\mathcal{F}_{pwKE}$ in the exchange of two parties by altering the behavior of the next query **NewKey**, according to the correct or incorrect guess.

- **NewKey** interface allows to give parties a session key consistent with the state of their record. If two fresh entities do not share/use the same password then $\mathcal{F}_{pwKE}$ does not give them the same key. Contrarily, if they do, this oracle returns the same key for both parties. However the behavior is more refined than that and takes account possible alterations from **TestPwd** (more details in Fig. 4).

Ideal Functionality with server authentication $\mathcal{F}_{pwKE-sA}$. We present a variation $\mathcal{F}_{pwKE-sA}$ of the previous ideal functionality to add explicit server authentication. A detailed description of the functionality is provided in Fig. 3.

- in each record in L (defined in Figure 3), we add a component **role** $\in \{\text{client}, \text{server}\}$. From this point forward, L has components of the form $(\text{ssid}, P_i, P_j, \text{pw}, \text{status}, \text{role})$.
- If the client queries **NewKey** at a time when the server still has not queried **NewKey** in the same session **ssid**, then $\mathcal{F}_{pwKE-sA}$ does nothing.
- If P_i and P_j do not share the same password: then the client gets **abort** whatever the **status** is.

Model. To prove that a protocol UC-emulates $\mathcal{F}_{pwKE}$ or $\mathcal{F}_{pwKE-sA}$, we first need to set the model and assumptions for the proof. In this paper, we consider the Random Oracle Model (ROM) and the Ideal Cipher (IC) model (more details in full version [BCP+23]). We also make use of the erasure model and assume that the adversary $\mathcal{A}$ is able to perform either adaptive or static corruptions, depending on the protocol.

Random Oracle. We use the definition of ROM introduced by Hofheinz and Müller-Quade [HM04]. This assumption provides a powerful tool that coherently responds to queries and generates answers that are uniformly random and independent of the input of the query.

Ideal Cipher. The ideal cipher model was first introduced in [BPR00]. It considers that a cipher behaves as a perfectly independent random permutation for every key used. We will generalize it a little bit by differentiating the input set and the output set, and then considering random bijections for every key.

Corruption. As mentioned earlier, we consider two types of corruptions in this paper: static corruptions and adaptive corruptions. Static corruptions allow the adversary to obtain the password of a party prior to the execution of the protocol. This means that during a simulation, the simulator knows which parties have been corrupted. Adaptive corruptions allow the adversary to corrupt any party during the execution of the protocol by revealing the password and internal state of the party.

Erasure model. The erasure model is a simple but powerful assumption. In this model, we assume that any internal information that is no longer useful ceases to exist. Therefore, in the event of information leakage, or adaptive corruption, previous internal information is not leaked as it no longer exists.

PAKE Ideal Functionality with server Authentication: $\mathcal{F}_{pwKE-sA}$ Session Initialization

On (**NewSession**, ssid, role, pw, P_i, P_j) from P_i :

- Sends (**NewSession**, ssid, role, P_i, P_j) to S .
- If this is the first **NewSession** query, or if it is the second **NewSession** query and there is a record $(ssid, P_j, P_i, pw', \star, \star) \in L$, then record $(ssid, P_i, P_j, pw, \text{fresh}, \text{role})$ in L .

Active attack

Upon receiving a query (**TestPwd**, ssid, P_i, pw') from the adversary $\mathcal{S}$, if there exists record $(ssid, P_i, P_j, pw, \text{fresh}, \text{role}) \in L$, do:

- If $pw = pw'$ mark the record as **compromised** and reply to $\mathcal{S}$ with "correct guess".
- If $pw \neq pw'$, mark the record as **interrupted** and reply to $\mathcal{S}$ with "wrong guess".

Key Generation

Upon receiving a query (**NewKey**, ssid, P_i, SK) from $\mathcal{S}$, where $SK \in \{\text{keys}\}$, if there is a record of the form $(ssid, P_i, P_j, pw, \text{status}, \text{role}) \in L$, for any value status, and this is the first **NewKey** query for P_i :

- if role = client
 - If status = **compromised**, or if one of the players P_i or P_j is corrupted and there exists two records $(ssid, P_i, P_j, pw, \text{client})$ and $(ssid, P_j, P_i, pw, \text{server})$ then send (ssid, SK) to P_i ;
 - Else if status = **fresh** and there is a record $(ssid, P_j, P_i, pw', \text{client}')$ with $pw' = pw$, and a session key SK' has been sent to P_j , that was **fresh** at that time, then send (ssid, SK') to P_i . Else if $pw' \neq pw$, choose a random key SK' whose length is k and send (ssid, SK') to P_i .
 - Else if status = **fresh**, and if no record **completed** record exists for P_j in ssid do nothing.
 - Else if status = **interrupted**, send (ssid, error) to P_i .
- if role = server
 - If status = **compromised**, or if one of the players P_i or P_j is corrupted then send (ssid, SK) to P_i ;
 - Else if status = **fresh** or status = **interrupted**, choose a random key $SK' \in \{\text{keys}\}$ and send (ssid, SK') to P_i .

Update the record as **completed**.

Fig. 3. $\mathcal{F}_{pwKE-sA}$: the ideal Functionality of a PAKE with server explicit authentication.

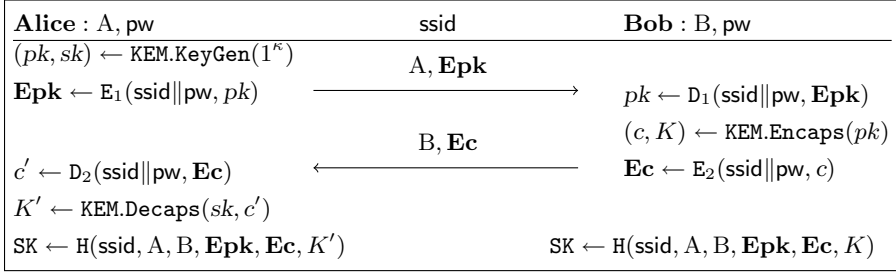


Fig. 4. CAKE with (E_1, D_1) , (E_2, D_2) two pairs of ideal ciphers. E_1 is a bijection from $\mathcal{P}$ to $\mathcal{P}'$ while E_2 is a bijection from $\mathcal{C}$ to $\mathcal{C}'$.

4 Two Pieces of One Cake: Study of EKE and OEKE

In this study, we propose to examine the use of KEM with specific properties in the context of EKE and One-Way Encrypted Key Exchange (OEKE). We first introduce an evolved version of EKE called CAKE, that provides implicit authentication only, and then extend it to OEKE using a variant called OCAKE, that additionally provides explicit authentication of the receiver. We prove the security of these protocols in the Universal Composability (UC) model, assuming three properties of the KEM: semantic security, fuzziness, and anonymity. These two studies offer a balance between security properties and efficiency: CAKE handles adaptive corruptions, while OCAKE is proven secure in a relaxed model that only allows static corruptions to provide explicit authentication.

4.1 CAKE

In this subsection, we present a study of the K(EM)-EKE protocol, referred to as CAKE. This protocol is based on the use of generic KEM in EKE and is the most conservative of the two constructions we propose.

To study CAKE properly, as well as expressing the necessary properties on the underlying KEM, we first fix a KEM ($\text{KeyGen}, \text{Encaps}, \text{Decaps}$) with the sets $\mathcal{SK}$, $\mathcal{P}$, $\mathcal{C}$, and $\mathcal{K}$ as in Definition 1. Next, we define two ideal cipher pairs (E_1, D_1) and (E_2, D_2) . We additionally define a set of keys Key and two sets $\mathcal{P}'$ and $\mathcal{C}'$ respectively bijections from $\mathcal{P}$ and $\mathcal{C}$ where both of them offer easy uniform sampling:

$$\begin{array}{ll}
 E_1 : \text{Key} \times \mathcal{P} \rightarrow \mathcal{P}' & E_2 : \text{Key} \times \mathcal{C} \rightarrow \mathcal{C}' \\
 D_1 : \text{Key} \times \mathcal{P}' \rightarrow \mathcal{P} & D_2 : \text{Key} \times \mathcal{C}' \rightarrow \mathcal{C}
 \end{array}$$

The actual keys of the ideal ciphers are the concatenations of the `ssid` and the passwords, to ensure independent bijections between different executions of the protocol. We introduce a description of CAKE in Fig. 4 along with its security theorem based on the fuzziness and anonymity of the underlying KEM in the ROM and IC models, while allowing adaptive corruptions.

Theorem 1. *Let (E_1, D_1) , (E_2, D_2) be two pairs of ideal ciphers and H be a random oracle. We note q_{D_1} (resp. q_{D_2}) the maximal number of queries to the decryption oracle D_1 (resp. D_2). We also note q_{E_1} (resp. q_{E_2}) the maximal number of queries to the encryption oracle E_1 (resp. E_2) explicitly asked by the adversary. Finally, we note q_s the number of sessions. The CAKE protocol described in Fig. 4 using KEM, a key encapsulation mechanism that is both fuzzy (Def. 3) and anonymous (Def. 4) ensuring semantic security, UC-emulates $\mathcal{F}_{pwKE}$ in the erasure model with adaptive corruptions. More precisely, if we define $\text{Adv}_{\text{KEM}}^{\text{cake}}(\mathcal{A})$ the advantage of an adversary $\mathcal{A}$ to break the above claim, it is bounded by*

$$\begin{aligned} & (2q_s + q_{D_1} + q_{D_2}) \cdot \text{Adv}_{\text{KEM}}^{\text{ind}}(t) \\ & + (q_s + q_{D_1}) \cdot \text{Adv}_{\text{KEM}}^{\text{fuzzy}}(t) + q_{D_1} \cdot (q_s + q_{D_2}) \cdot \text{Adv}_{\text{KEM}}^{\text{ano}}(t) \\ & + q_H \cdot q_s \cdot 2^{-\lambda_k} + q_{E_1}^2 \cdot 2^{-\lambda_p-1} + q_{E_2}^2 \cdot 2^{-\lambda_c-1}, \end{aligned}$$

where λ_k is the bit-length of the encapsulated keys, λ_p the bit-length of the public keys, and λ_c the bit-length of the ciphertexts, for the KEM scheme.

Sketch of Proof: In the subsequent games, we denote $\Pr[\mathbf{G}]$ the probability for the environment $\mathcal{Z}$ to output 1 in the simulated game $\mathbf{G}$. The goal is to prove that $\Pr[\mathbf{G}]$ is close to the probability to output 1 in the ideal game, while starting from the real game $\mathbf{G}_0$. The sequence of games will end with $\mathbf{G}_9$ that only uses the ideal functionality $\mathcal{F}_{pwKE}$, and is thus the ideal game. The complete simulation can be found in the Appendix A and the complete proof in the Appendix of the full version ([BCP+23]). We present here a sketch of proof:

- G₀:** Real world protocol using the following assumptions: erasure model, random oracle, ideal cipher, adaptive corruption and lastly a fuzzy and anonymous KEM, which is also indistinguishable.
- G₁:** Honest simulation of the random oracle H and the pairs of ideal ciphers (E_1, D_1) and (E_2, D_2) from Fig. 4, where we abort in case of collision during explicit encryption calls. Additionally, a private simulation of a random oracle H^* used for the simulation when $\mathcal{S}$ cannot extract private information.
- G₂:** Embedding of the secrets during the simulation of D_1 and D_2 .
- G₃:** Simulation of Alice's initialization with D_1 instead of E_1 .
- G₄:** Simulation of Bob's answer with D_2 instead of E_2 .
- G₅:** Preparation of Alice's reaction, by anticipating all the possible public keys decrypted by D_1 when a query is asked to D_2 .
- G₆:** Simulation of Alice's reaction, using the previous simulation of D_2 .
- G₇:** Random session keys, where we replace all the unknown keys SK by random values.
- G₈:** Adaptive corruptions, where we program the random oracle H and provide the secret values in case of corruption.
- G₉:** Using on queries from $\mathcal{F}_{pwKE}$ to detail the simulator in the ideal world.

A precise simulator is defined in Appendix A with Figs. 6, 7 and 8. □

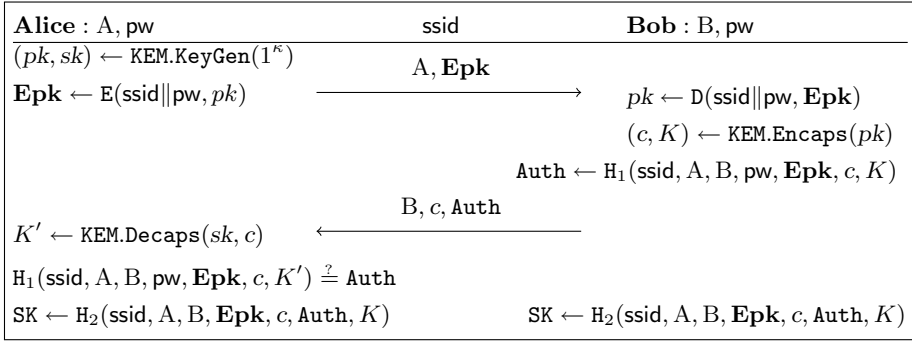


Fig. 5. OCAKE with (E, D) an ideal cipher. E is a bijection from $\mathcal{P}$ to $\mathcal{P}'$.

Remark 1. Instantiated with the KEM derived from ElGamal presented in Sect. 2, CAKE-ElGamal is exactly the famous EKE [BM92]. But the proof technique actually differs because ElGamal enjoys perfect fuzziness (or smoothness) and perfect anonymity, which facilitate the EKE security proof. However, post-quantum algorithms cannot validate all these strong properties.

4.2 OCAKE

In this subsection, we modify the above CAKE protocol by adding explicit authentication of the receiver, which allows to remove one encryption. The modifications are based on the OEKE [BCP03] protocol but with generic KEM protocols instead of a Diffie-Hellman based key exchange.

In this setting, we only handle static corruptions in the security model. Indeed, it would have been possible to include adaptive corruptions in the security model with a statistical notion for the anonymity, i.e. perfect anonymity. But the computational property of our anonymity definition (see Definition 4) is more realistic for post-quantum KEM protocols. And thus here, adaptive corruptions cannot be handled by our proof in the UC-framework: in case of honest transcripts, we must generate a random c , on behalf of Bob. In case of Alice's corruption, one can program E in order to set a specific (pk, sk) , but if the simulator commits on a specific c , then it cannot remain consistent. In particular, the adversary could have tried many passwords when decrypting $\mathbf{Epk}$, hence one cannot anticipate the public key for c .

In order to thoroughly study this approach, we outline the modifications in Fig. 5. We remove one encryption on the server flow to change it into an authentication. However for the sake of the proof, we have to slightly change how the hash query is usually done. Instead of using the public transcript, we use part of the secret information for the sake of the simulation in the security proof.

Lastly we use $\mathcal{F}_{pwKE-sA}$ in Fig. 3: the PAKE ideal functionality with explicit authentication of the server.

Theorem 2. *Let (E, D) be a pair of ideal cipher. Let H_1 and H_2 be two random oracles. We note q_D the maximal number of queries to the decryption oracle D . We also note q_E the maximal number of queries to the encryption oracle E , explicitly asked by the adversary. And we note q_s the number of sessions. The OCAKE protocol described in Fig. 5 using KEM, a key encapsulation mechanism that is both fuzzy (Def. 3) and anonymous (Def. 4) while ensuring semantic security, UC-emulates $\mathcal{F}_{pwKE-sA}$ in the erasure model with static corruptions. More precisely, if we define $\text{Adv}_{\text{KEM}}^{\text{ocake}}(\mathcal{A})$ the advantage of an adversary $\mathcal{A}$ to break the above claim is bounded by*

$$(q_s + q_D) \cdot \text{Adv}_{\text{KEM}}^{\text{fuzzy}}(t) + (q_s + q_D + 1) \cdot \text{Adv}_{\text{KEM}}^{\text{ind}}(t) + q_D \cdot \text{Adv}_{\text{KEM}}^{\text{ano}}(\mathcal{A}) \\ + (q_{H_1} + 2q_s)^2 \cdot 2^{-\lambda_{H_1} - 1} + q_E^2 \cdot 2^{-\lambda_p - 1} + (q_{H_1} + q_{H_2}) \cdot q_s \cdot 2^{-\lambda_k},$$

where λ_k is the bit-length of the encapsulated keys, λ_p the bit-length of the public keys for the KEM scheme, and λ_{H_1} the bit-length of the authentication tag.

Sketch of Proof: Similarly to the proof of Theorem 1, in the subsequent games, we denote $\Pr[\mathbf{G}]$ the probability for the environment $\mathcal{Z}$ to output 1 in the simulated game $\mathbf{G}$. The goal is to prove that $\Pr[\mathbf{G}]$ is close to the probability to output 1 in the ideal game, while starting from the real game $\mathbf{G}_0$. The sequence of games will end with $\mathbf{G}_8$ that only uses the ideal functionality $\mathcal{F}_{pwKE-sA}$, and is thus the ideal game. The complete simulation can be found in the Appendix B and the complete proof is depicted in the same Appendix of the full version ([BCP+23]). We present here a sketch of proof:

- $\mathbf{G}_0$: *Real* world protocol using the following assumptions: erasure model, random oracle, ideal cipher, static corruption and lastly a fuzzy and anonymous KEM, which is also indistinguishable.
- $\mathbf{G}_1$: Honest simulation of two random oracles H_1, H_2 and an ideal cipher (E, D) from Fig. 5, where we abort in case of collision during explicit encryption calls. Additionally a private simulation of each random oracle H_1^*, H_2^* used for the simulation when $\mathcal{S}$ does not know any passwords. We also exclude collisions on H_1 and H_1^* .
- $\mathbf{G}_2$: Embedding of the secret keys during the simulation of D .
- $\mathbf{G}_3$: Simulation of an adversary finding Auth by chance.
- $\mathbf{G}_4$: Simulation of Alice's initialization with D instead of E .
- $\mathbf{G}_5$: Simulation of Bob's answer with (c, Auth) .
- $\mathbf{G}_6$: Simulation of Alice's reaction, using the Auth and the abortion in case the authentication is not verified.
- $\mathbf{G}_7$: Random session keys, where we replace all the unknown authentication tags Auth and keys SK by random values, except for correctly guessed passwords
- $\mathbf{G}_8$: Using on queries from $\mathcal{F}_{pwKE-sA}$ to detail the simulator in the ideal world.

A precise simulator is defined in Appendix B with Figs. 9 and 10. □

Remark 2. Comparatively to remark 1, instantiated with the KEM derived from ElGamal presented in Sect. 2, OCAKE-ElGamal is exactly OEKE [ACCP08].

Additional remarks:

Removing the cipher on pk and keeping it on c like OEKE is not possible.

To follow strictly its framework one would need a perfectly anonymous KEM otherwise the client could construct a subset attack using the gap of a miscon-structed cipher on decryption. Furthermore, we place our study in the con-text of quantum-secure KEM and none of them allows for perfect anonymity. Therefore the strict OEKE framework is not an enticing approach for long-term usability.

This protocol is only secure against static corruptions. An adversary allowed to apply adaptive corruptions could corrupt the client a reception of (c, Auth) before it computes Decaps . The adversary would then obtain sk because Decaps needs it and implies that the erasure is not applied. Knowing sk , a random $c \leftarrow \mathcal{C}$ is easily recognizable from a honestly built one leading the adversary to distinguish the simulation in the above proof.

Adding an authentication of the client afterwards for mutual authentication is entirely possible. The proof extensively use tricks before the derivation of the session key to either extract private information or to send indistinguishable random elements. Since this is done before, either the client would send a honest authentication, a perfectly indistinguishable one or a recognizable wrong one.

5 Crystal-Kyber

5.1 Security Properties

Crystals-Kyber has been introduced in Sect. 2. For the following results, we set $\mathcal{P} = \{0, 1\}^\kappa \times \mathcal{R}_q^k$, $\mathcal{SK} = \beta_\eta^k$, $\mathcal{C} = \mathcal{R}_q^k \times \mathcal{R}_q$ and $\mathcal{K} = \{0, 1\}^n$. First of all, we recall the indistinguishability property of Crystals-Kyber [BDK+18]:

Lemma 1. *Kyber on parameters (k, η, q, n) is an indistinguishable KEM:*

$$\text{Adv}_{\text{Kyber}}^{\text{ind}}(\mathcal{A}) \leq \text{Adv}_{k,k,\eta}^{\text{d-mlwe}}(t) + \text{Adv}_{k+1,k,\eta}^{\text{d-mlwe}}(t)$$

Next, let us verify the anonymity and fuzziness properties guaranteed by Kyber.

Lemma 2. *Crystals-Kyber is an anonymous KEM in $\mathcal{C} = \mathcal{R}_q^k \times \mathcal{R}_q$:*

$$\text{Adv}_{\text{Kyber}}^{\text{ano}}(\mathcal{A}) \leq \text{Adv}_{k,k,\eta}^{\text{d-mlwe}}(t) + \text{Adv}_{k+1,k,\eta}^{\text{d-mlwe}}(t)$$

Proof. Let sample a public key $pk \leftarrow \$(\mathbf{A}, \mathbf{b})$, by definition of **Kyber** in Fig. 1

$$c = (\mathbf{u}, v) \text{ with } \begin{cases} \mathbf{u} = \mathbf{A}^T \cdot \mathbf{r} + \mathbf{e}' \\ v = \mathbf{b}^T \cdot \mathbf{r} + e'' + \lceil \frac{q}{2} \rceil \cdot m \end{cases}$$

We can rewrite c as:

$$\begin{bmatrix} \mathbf{u} \\ v \end{bmatrix} \leftarrow \begin{bmatrix} \mathbf{A} \\ \mathbf{b} \end{bmatrix}^T \mathbf{r} + \begin{bmatrix} \mathbf{e}' \\ e'' + \lceil \frac{q}{2} \rceil \cdot m \end{bmatrix}$$

It forms a Module-LWE instance $\left(\begin{bmatrix} \mathbf{A} \\ \mathbf{b} \end{bmatrix}^T, \begin{bmatrix} \mathbf{u} \\ v \end{bmatrix} \right)$ provided that $(\mathbf{A}, \mathbf{b})$ is uniformly random on $\mathcal{R}_q^{k \times k} \times \mathcal{R}_q^k$ which is true under the $\mathbf{d}\text{-MLWE}_{k,k,\eta}$ assumption. This directly gives:

$$\text{Adv}_{\text{Kyber}}^{\text{ano}}(\mathcal{A}) \leq \text{Adv}_{k+1,k,\eta}^{\text{d-mlwe}}(t) + \text{Adv}_{k,k,\eta}^{\text{d-mlwe}}(t)$$

□

To prove anonymity in lemma 2, **Kyber** needs to ensure the decisional MLWE argument, therefore:

Corollary 1. *Crystals-Kyber is a fuzzy KEM with $\mathcal{P} = \mathcal{R}_q^k$:*

$$\text{Adv}_{\text{Kyber}}^{\text{fuzzy}}(\mathcal{A}) \leq \text{Adv}_{k,k,\eta}^{\text{d-mlwe}}(t)$$

Theorem 3. *Let $(\mathbf{E}_1, \mathbf{D}_1)$, $(\mathbf{E}_2, \mathbf{D}_2)$ be two pairs of ideal ciphers, and $\mathbf{H}$ a random oracle. We note $q_{\mathbf{D}_1}$ (resp. $q_{\mathbf{D}_2}$) the maximal number of queries to the decryption oracle $\mathbf{D}_1$ (resp. $\mathbf{D}_2$), explicitly asked by the adversary, and q_s the number of session. The CAKE protocol from Fig. 4 instantiated with **Kyber** UC-emulates $\mathcal{F}_{pwKE}$ in the erasure model with adaptive corruptions:*

$$\begin{aligned} \text{Adv}_{\text{Kyber}}^{\text{cake}}(\mathcal{A}) &\leq ((5q_s + 3q_{\mathbf{D}_1} + 2q_{\mathbf{D}_2}) + 2q_{\mathbf{D}_1} \cdot (q_s + q_{\mathbf{D}_2})) \cdot \text{Adv}_{k+1,k,\eta}^{\text{d-mlwe}}(t) \\ &\quad + q_{\mathbf{H}} \cdot q_s \cdot 2^{-n} + q^{-kn} \cdot (q_{\mathbf{E}_1}^2 \cdot 2^{-\kappa} + q_{\mathbf{E}_2}^2 \cdot q^{-n})/2 \end{aligned}$$

Theorem 4. *Let $(\mathbf{E}, \mathbf{D})$ be an ideal cipher, and $\mathbf{H}_1, \mathbf{H}_2$ two random oracles. We note $q_{\mathbf{D}}$ the maximal number of queries to the decryption oracle $\mathbf{D}$, explicitly asked by the adversary, and q_s the number of session. The OCAKE protocol from Fig. 5 instantiated with **Kyber** UC-emulates $\mathcal{F}_{pwKE-sA}$ in the erasure model with static corruptions:*

$$\begin{aligned} \text{Adv}_{\text{Kyber}}^{\text{ocake}}(\mathcal{A}) &\leq 2 \cdot q_{\mathbf{D}} \cdot (\text{Adv}_{k+1,k,\eta}^{\text{d-mlwe}}(t)) + 3 \cdot q_{\mathbf{D}} \cdot (\text{Adv}_{k,k,\eta}^{\text{d-mlwe}}(t)) \\ &\quad + (q_{\mathbf{H}_1} + q_{\mathbf{H}_2}) \cdot q_s \cdot 2^{-n} + q_{\mathbf{E}}^2 \cdot 2^{-\kappa} + q_{\mathbf{H}_1} \cdot 2^{-n} \end{aligned}$$

5.2 Instantiation of the Block Cipher

To prove the UC-security of both CAKE-Kyber and OCAKE-Kyber, the ideal cipher model is crucial. More precisely it needs to ensure that finding a collision on the encryption is statistically impossible without querying a decryption oracle. It removes both the following approaches out of the equation: stream cipher and one time pad. The conception of a relevant block cipher for our transformations is actually nontrivial. In fact, the underlying sets, like $\mathcal{R}_q$, are not convenient for building a symmetric block cipher statistically following the necessary ideal properties. We present here a solution issued from known ad-hoc techniques. We believe that it can be improved for better performance but this task is left as future work.

To keep light notations, we do not encrypt the seed of $\mathbf{A}$, and thus consider the encryption of an element in $\mathcal{R}_q^k \sim \mathbb{Z}_q^{n \times k}$ for the public key. We can do the same with $\mathcal{R}_q^k \times \mathcal{R}_q \sim \mathbb{Z}_q^{n \times (k+1)}$ for the ciphertext.

To encrypt $pk \in \mathcal{R}_q^k \sim \mathbb{Z}_q^{n \times k}$, we can first encode pk into $\{0, \dots, q^{nk} - 1\}$, and then use a block cipher on ℓ -bits, such that $2^{\ell-1} \leq q^{nk} < 2^\ell$. We thus have an encoding/decoding from $\mathcal{R}_q^k$ to $\{0, 1\}^\ell$ that can be seen as a superset of $\{0, \dots, q^{nk} - 1\}$. Let us thus consider all these encodings equivalent.

From (E, D) on ℓ -bit blocks and κ -bit keys, we can build a permutation onto the restricted set $\{0, \dots, q^{nk} - 1\}$: one defines the encryption scheme with key K on $\mathbf{b} \in \mathcal{R}_q^k \sim \{0, \dots, q^{nk} - 1\}$ as $\mathbf{E}'_K(\mathbf{b}) = \mathbf{E}_K(\dots \mathbf{E}_K(\mathbf{b}) \dots)$, stopping at the first element in $\{0, \dots, q^{nk} - 1\}$. Decryption works the same way, and will stop at the right place as all ignored intermediate values are outside the expected set.

Actually, the number of iterations will be small, as there is a probability less than $1/2$ at each step. This technique is vulnerable to timing attacks, but one can always include virtual loops.

We emphasize that this study is done without using the optimized **Kyber** (without) the **compression**, **decompression** functions. However, these two functions map elements of $\mathbb{Z}_q$ to $\mathbb{Z}_{q'}$ with $q' < q$, therefore the study remains similar.

5.3 Parameters

The bounds in Theorems 3 and 4 are slightly looser than the ones that constrain the choice of parameters for **Kyber**. Thus, some adaptations of the obtained security levels are necessary. We propose to recompute the security level for the set of parameters taken from **Kyber**'s last submission to the NIST [SAB+22] and choosing parameters that allow to reach around 100 bits of security against quantum adversaries. While this can be argued to be weak, **PAKE** are not used in highly critical applications but in highly efficient ones. Hence, 100 bits of security against quantum adversaries would constitute a mid to long-term security target.

We present in Table 1 the security estimations for CAKE-Kyber and OCAKE-Kyber obtained with the pq-crystal estimate [DS21] against a quantum adversary with **KYBER768** and **KYBER1024** parameters.

Table 1. Bit security estimates of CAKE-Kyber and OCAKE-Kyber using parameters from version 3.0 of the NIST [SAB+22] against a quantum adversary. Estimation done using python script from pqcrystals github [DS21].

Kyber parameters	Bit-sec against quantum adversaries obtained with [DS21]
Kyber1024	102

CAKE-Kyber

Kyber768	98
Kyber1024	162

OCAKE-Kyber

The security/efficiency trade-off between CAKE and OCAKE is confirmed in this example. According to Table 1, CAKE provides more conservative assumptions as an adaptive adversary are included in the model however it is less efficient than its OCAKE alternative.

We emphasize the fact that this paper propose a generic construction proven secure in the UC model. To our knowledge before this work no UC-secure lattice-based PAKE are usable in practice. However BPR-secure PAKE such as [GDLL17] should be slightly more efficient in practice due to our reduction. One benefit of our approach is that the efficient and secure implementation of **Kyber** can directly be applied.

6 Conclusion and Perspectives

In this article we characterize the necessary properties for a key encapsulation mechanism to be used in a password authenticated key exchange and more precisely in both EKE and OEKE. Additionally we prove that these properties are respected by the newly standardized **Kyber**. To supplement this study we introduce a set of possible parameters for **Kyber**, ensuring around 100 bit of security. Lastly we propose a cipher respecting statistically ideal cipher properties for the application of both CAKE (Fig. 4) and (OCAKE Fig. 5).

While our work focuses on post-quantum alternatives, one could improve our results by supposing a random self-reducible KEM (like El-Gamal). Random self-reducibility implies that arbitrarily many independant instances can be reduced

to only one such instance. Although current post-quantum schemes are not self-reducible KEM but such an assumption would lead to tighter reductions and it would allow for SPEKE or CPace constructions to be generalized to more KEM protocols.

Acknowledgements. We would like to thank Olivier Blazy and Henri Gilbert respectively for useful discussions about password-authenticated key exchange protocols and their security and symmetric encryption for the PAKE practicability. This work was supported in part by the French Programme d'Investissement d'Avenir (PIA) under national project RESQUE and by the French ANR projects CryptiQ (ANR-18-CE39-0015) and SecNISQ (ANR-21-CE47-0014). The first author was also supported by ANRT under the program CIFRE N° 2021/0645.

References

- ABC+22. Albrecht, M.R., et al.: Classic McEliece. Technical report, National Institute of Standards and Technology (2022). <https://csrc.nist.gov/projects/post-quantum-cryptography/round-4-submissions>
- ACCP08. Abdalla, M., Catalano, D., Chevalier, C., Pointcheval, D.: Efficient two-party password-based key exchange protocols in the UC framework. In: Malkin, T. (ed.) CT-RSA 2008. LNCS, vol. 4964, pp. 335–351. Springer, Heidelberg (2008). https://doi.org/10.1007/978-3-540-79263-5_22
- ADPS16. Alkim, E., Ducas, L., Pöppelmann, T., Schwabe, P.: NewHope without reconciliation. Cryptology ePrint Archive, Report 2016/1157 (2016). <https://eprint.iacr.org/2016/1157>
- AHH21. Abdalla, M., Haase, B., Hesse, J.: Security analysis of CPace. In: Tibouchi, M., Wang, H. (eds.) ASIACRYPT 2021. Part IV, volume 13093 of LNCS, pp. 711–741. Springer, Heidelberg (2021). https://doi.org/10.1007/978-3-030-92068-5_24
- AHH22. Abdalla, M., Haase, B., Hesse, J.: CPace, a balanced composable PAKE. Internet-Draft draft-irtf-cfrg-pace-06, Internet Engineering Task Force. Work in Progress, July (2022)
- BCP03. Bresson, E., Chevassut, O., Pointcheval, D.: Security proofs for an efficient password-based key exchange. In: Jajodia, S., Atluri, V., Jaeger, T., editors, ACM CCS 2003, pp. 241–250. ACM Press, October (2003)
- BCP+23. Beguinet, H., Chevalier, C., Pointcheval, D., Ricosset, T., Rossi, M.: Get a cake: generic transformations from key encapsulation mechanisms to password authenticated key exchanges. Cryptology ePrint Archive, Paper 2023/470 (2023). <https://eprint.iacr.org/2023/470>
- BCV19. Blazy, O., Chevalier, C., Huy Vu, Q.: Post-quantum uc-secure oblivious transfer in the standard model with adaptive corruptions. In: Proceedings of the 14th International Conference on Availability, Reliability and Security, ARES 2019, Canterbury, UK, August 26–29, 2019, pp. 28:1–28:6. ACM (2019)
- BDK+18. Bos, J.W.: CRYSTALS - kyber: a cca-secure module-lattice-based KEM. In: 2018 IEEE European Symposium on Security and Privacy, EuroS&P 2018, London, United Kingdom, April 24–26, 2018, pp. 353–367. IEEE (2018)
- BM92. Bellare, S.M., Merritt, M.: Encrypted key exchange: password-based protocols secure against dictionary attacks. In: 1992 IEEE Symposium on Security and Privacy, pp. 72–84. IEEE Computer Society Press, May (1992)

- BPR00. Bellare, M., Pointcheval, D., Rogaway, P.: Authenticated key exchange secure against dictionary attacks. In: Preneel, B. (ed.) EUROCRYPT 2000. LNCS, vol. 1807, pp. 139–155. Springer, Heidelberg (2000). https://doi.org/10.1007/3-540-45539-6_11
- Can01. Canetti, R.: Universally composable security: a new paradigm for cryptographic protocols. In: 42nd FOCS, pp. 136–145. IEEE Computer Society Press, October (2001)
- CHK+05. Canetti, R., Halevi, S., Katz, J., Lindell, Y., MacKenzie, P.D.: Universally composable password-based key exchange. In: Cramer, R. (ed.) EUROCRYPT 2005. LNCS, vol. 3494, pp. 404–421. Springer, Heidelberg (2005). https://doi.org/10.1007/11426639_24
- CR03. Canetti, R., Rabin, T.: Universal composition with joint state. In: Boneh, D. (ed.) CRYPTO 2003. LNCS, vol. 2729, pp. 265–281. Springer, Heidelberg (2003)
- DHP+18. Dupont, P.-A., Hesse, J., Pointcheval, D., Reyzin, L., Yakubov, S.: Fuzzy password-authenticated key exchange. In: Nielsen, J.B., Rijmen, V. (eds.) EUROCRYPT 2018. LNCS, vol. 10822, pp. 393–424. Springer, Cham (2018). https://doi.org/10.1007/978-3-319-78372-7_13
- DKR+20. D’Anvers, J.-P. et al.: SABER. Technical report, National Institute of Standards and Technology (2020). <https://csrc.nist.gov/projects/post-quantum-cryptography/round-3-submissions>
- DKRV18. D’Anvers, J.-P., Karmakar, A., Sinha Roy, S., Vercauteren, F.: Saber: module-LWR based key exchange, CPA-secure encryption and CCA-secure KEM. In: Joux, A., Nitaj, A., Rachidi, T. (eds.) AFRICACRYPT 2018. LNCS, vol. 10831, pp. 282–305. Springer, Cham (2018). https://doi.org/10.1007/978-3-319-89339-6_16
- DS21. Ducas, L., Schanck, J.: pq-crystals/security-estimates. <https://github.com/pq-crystals/security-estimates> (2021)
- ElG85. ElGamal, T.: A public key cryptosystem and a signature scheme based on discrete logarithms. IEEE Trans. Inf. Theory **31**, 469–472 (1985)
- GDLL17. Gao, X., Ding, J., Liu, J., Li, L.: Post-quantum secure remote password protocol from RLWE problem. Cryptology ePrint Archive, Report 2017/1196 (2017). <https://eprint.iacr.org/2017/1196>
- HM04. Hofheinz, D., Müller-Quade, J.: Universally composable commitments using random oracles. In: Naor, M. (ed.) TCC 2004. LNCS, vol. 2951, pp. 58–76. Springer, Heidelberg (2004). https://doi.org/10.1007/978-3-540-24638-1_4
- LS15. Langlois, A., Stehlé, D.: Worst-case to average-case reductions for module lattices. Des. Codes Cryptogr. **75**(3), 565–599 (2015)
- Mac01. MacKenzie, P.: On the security of the SPEKE password-authenticated key exchange protocol. Cryptology ePrint Archive, Report 2001/057 (2001). <https://eprint.iacr.org/2001/057>
- McE78. McEliece, R.J.: A public-key cryptosystem based on algebraic coding theory. The deep space network progress report 42–44, Jet Propulsion Laboratory, California Institute of Technology, January/February (1978). https://ipnpr.jpl.nasa.gov/progress_report2/42-44/44N.PDF
- PAA+19. Poppelmann, T., et al.: NewHope. Technical report, National Institute of Standards and Technology (2019). <https://csrc.nist.gov/projects/post-quantum-cryptography/round-2-submissions>
- Reg06. Regev, O.: Lattice-based cryptography. In: Dwork, C. (ed.) CRYPTO 2006. LNCS, vol. 4117, pp. 131–141. Springer, Heidelberg (2006). https://doi.org/10.1007/11818175_8

- SAB+22. Schwabe, P., et al.: CRYSTALS-KYBER. Technical report, National Institute of Standards and Technology (2022). <https://csrc.nist.gov/Projects/post-quantum-cryptography/selected-algorithms-2022>
- Sch17. Schmidt, J.-M.: Requirements for password-authenticated key agreement (PAKE) schemes. RFC **8125**, 1–10 (2017)
- ZY17. Zhang, J., Yu, Yu.: Two-round PAKE from approximate SPH and instantiations from lattices. In: Takagi, T., Peyrin, T. (eds.) ASIACRYPT 2017. Part III, volume 10626 of LNCS, pp. 37–67. Springer, Heidelberg (2017). https://doi.org/10.1007/978-3-319-70700-6_2